

AI GOVERNANCE DECISION MEMO

Disposition of Two High-Risk AI Systems and Establishment of an AI Governance Program

To: Executive Leadership Team | From: GRC Lead, with General Counsel and CISO | Date: 2026-07-29

Sample GRC portfolio artifact — fictional company. Not legal advice.

1. Decision Required

Leadership is asked to make three decisions by 31 August 2026:

1. Disposition of ClaimSight Adjudication Assist (AI-001), which is operating for three EU-based client plans as an unassessed high-risk AI system.
2. Disposition of the Recruiting Resume Screener pilot (AI-004), a third-party high-risk system for which the vendor will not provide bias audit results.
3. Establishment of an AI Governance Committee and adoption of an AI policy, which is the root-cause remediation for how the first two situations arose.

This memo lays out the situation, the options considered, and a recommendation for each. It is deliberately short. The supporting analysis is in the AI System Inventory, the AI Risk Assessment, and the AI Governance Control Crosswalk.

2. How We Got Here

Halcyon deployed nine AI systems over roughly thirty months. None went through a governance review, because no governance function existed. Each business unit made a locally reasonable decision; the aggregate is that the company now operates two systems that meet the EU AI Act's definition of high-risk — one in production, one in pilot — with none of the documentation, testing, or oversight design that classification requires.

This is not unusual. It is the modal state of mid-size organizations in 2026. It is also not sustainable, because the regulatory calendar has started to move and because the harms these systems can cause — discriminatory benefit denials, discriminatory hiring shortlists — are real regardless of what any regulator does.

On the timeline

EU AI Act high-risk obligations were scheduled to apply from 2 August 2026. A May 2026 proposal, the Digital Omnibus, would defer that to 2 December 2027 for standalone systems. As of this memo the deferral is proposed and not adopted. Two observations. First, planning to the later date and being wrong is materially costlier than planning to the earlier date and having slack. Second, and more important: the deferral changes when enforcement begins, not whether the systems are causing harm now. AIR-001 — the risk that ClaimSight encodes historical bias in denial recommendations — does not have a compliance date. It is either happening or it isn't, and we currently do not know which.

3. Decision 1 — ClaimSight Adjudication Assist (AI-001)

What it does	Recommends approve / deny / pend on benefit claims. Adjuster confirms each recommendation.
Why it is high-risk	Access to essential private services (Annex III). Materially influences benefit outcomes for individuals. Three EU-based client plans in scope.
Current governance	None. No fairness testing, no drift monitoring, no technical documentation, no conformity

	assessment, no EU registration.
Key finding	Adjuster override rate is 3%. At that rate the human is ratifying, not reviewing. The 'human-in-the-loop' control that everyone assumed was there is nominal.
Residual risk after planned controls	Critical (AIR-004). Controls reduce bias and drift risk; they do not resolve the regulatory position for the EU plans.

Options

Option	Description	Assessment
A	Build the conformity path: full risk management system, data governance, fairness testing, technical documentation, oversight redesign, EU registration. Continue serving all plans.	Right long-term answer if the EU book is strategic. Cost is high (est. 9–12 months, dedicated data science + legal effort). Requires the deferral to hold to be comfortably achievable; if it doesn't, we are non-compliant in production for months.
B	Carve the three EU plans out to manual adjudication immediately. Continue ClaimSight for US plans while building governance controls at a sustainable pace. Re-onboard EU plans to ClaimSight once conformity is achieved.	Removes the acute regulatory exposure now. Costs ~2.5 FTE in adjudication capacity for EU plans (roughly 4% of claim volume). Buys time to do Option A properly. Does not remove the underlying fairness risk for US plans — that work must proceed regardless.
C	Exit the EU book.	Not proportionate. Three plans; the exposure is manageable through B. Reserved as fallback if conformity cost proves prohibitive.
D	Do nothing pending final Digital Omnibus text.	Rejected. Bets the company's regulatory position on a proposal, and ignores that the fairness risk exists independent of the calendar.

Recommendation: Option B, with Option A as the committed follow-on

Carve EU plans out to manual adjudication within 30 days. Simultaneously begin the fairness testing (AIR-001), explainability (AIR-002), and drift monitoring (AIR-003) work for the US deployment — that work is required on its merits and is also the bulk of the conformity path. Set a checkpoint at 90 days to decide whether to commit to full EU conformity (Option A) or hold EU plans on manual adjudication indefinitely.

The reasoning: B is reversible and A is not. B costs adjudication capacity for a quarter; A costs a year of effort that could be wasted if the deferral collapses the timeline or if fairness testing reveals the model needs to be rebuilt. Take the reversible action first, learn from the fairness results, then commit.

4. Decision 2 — Recruiting Resume Screener (AI-004)

What it does	Ranks applicants; recruiter reviews the top 20.
Why it is high-risk	Employment (Annex III). Dublin recruiting creates EU exposure; NYC roles trigger Local Law 144's independent bias audit requirement.
Current governance	None. Vendor declines to disclose training data or provide bias audit results.
Key finding	Candidates ranked 21st and below are never seen by a human. For those applicants, this is a fully automated adverse decision, whatever the vendor's marketing says about 'assistive' ranking.
Residual risk after planned controls	Critical (AIR-005) — because the controls we would need depend on vendor cooperation we do not have.

Recommendation: Pause the pilot. Condition resumption on the vendor.

Pause immediately — this is a pilot, so pausing costs little. Notify the vendor in writing that resumption requires (a) a third-party bias audit report meeting NYC Local Law 144 standards, and (b) transparency documentation sufficient for EU AI Act Article 13. Give them 60 days. If they can't or won't provide it, terminate and evaluate alternatives that can.

This is the easy decision and it is worth naming why. A vendor that will not show you bias audit results for a hiring tool is telling you something. The organization should not need a governance committee to act on that signal, but the fact that the pilot ran for four months without anyone acting on it is precisely why the committee is needed.

5. Decision 3 — Establish AI Governance

Both situations above share a root cause: no one was accountable for asking whether an AI system should exist before it did. The remediation is structural, not technical.

Recommendation

- Charter an AI Governance Committee within 30 days. Chair: General Counsel. Members: CISO, CIO, Chief Actuary, VP People, Head of Compliance, GRC Lead as secretariat. Quarterly cadence; ad hoc for new system approval.
- Adopt an AI Policy covering acceptable use, mandatory intake review for new AI systems, prohibition on consumer AI tools for sensitive data, and system-owner accountability. Attestation for all staff.
- Assign a named business owner to every system in the inventory. Owners are accountable for their system's risk assessment currency and control implementation.
- Adopt NIST AI RMF as the operating method and ISO/IEC 42001 as the target management-system standard. Do not pursue 42001 certification in year one; use its structure to build the program so certification is available later without rework.
- Fund a fairness-testing capability — either a data-science hire with the skill set or a retained third party. Two of the three critical risks depend on it.

This is roughly one senior hire and a modest tooling budget. It is small relative to the exposure it addresses, and smaller than the cost of the first regulatory inquiry or discrimination claim.

6. What This Memo Does Not Recommend

It does not recommend halting AI adoption. Six of nine systems in the inventory are appropriately governed or trivially fixable, and several — document OCR, actuarial forecasting, marketing drafting — deliver clear value at low risk. The point of governance is to make it possible to say yes with confidence, not to say no by default. An organization that responds to this memo by freezing AI will have learned the wrong lesson.

7. Summary of Asks

#	Ask	Owner	By
1	Approve carve-out of EU plans from ClaimSight to manual adjudication; fund fairness/explainability/drift work for US deployment; 90-day checkpoint on full EU conformity	VP Claims Ops + GC	2026-08-31
2	Approve pause of Resume Screener pilot and vendor conditions for resumption	VP People	2026-08-15

3	Charter AI Governance Committee; adopt AI Policy; assign system owners	GC	2026-08-31
4	Fund fairness-testing capability (hire or retained)	CIO / CFO	2026-09-30

8. Sources and Caveats

Analysis draws on NIST AI RMF 1.0 and the Generative AI Profile (AI 600-1), ISO/IEC 42001:2023, the EU AI Act as adopted (Regulation (EU) 2024/1689) with the May 2026 Digital Omnibus proposal noted as unadopted, and NYC Local Law 144. This is a portfolio artifact for a fictional company; regulatory citations are for demonstration and would require verification by counsel before reliance in any real decision.